PayNest Technologies

Security & Compliance Assessment Report

Asset inventory | Risk register | ISO 27001 / NIST CSF 2.0 mapping

Access review | Log retention audit | Remediation plan

Prepared by	Ammar Badlawala
Report date	4 November 2026
Data as at	Access review and log audit: 25 Oct 2026. Remediation plan: 2 Nov 2026.
Source workbook	PayNest_Compliance_Assessment_Final.xlsx (14 tabs, v9)
Status	Fictional case study for portfolio practice. All names, accounts, dates and settings are invented. This is not an audit opinion, certification or legal advice.

About this report

PayNest is an invented payroll and employee-management SaaS company in Mumbai with 35 staff, about 250 small-business customers and roughly 12,000 customer employee records hosted on AWS (ap-south-1). This report turns the assessment workbook into a readable summary: what was assessed, what was found, how serious it is, and what should be fixed first.

1. Executive summary

Overall picture. PayNest has some sensible foundations (admin MFA, daily backups, AWS-native logging in Mumbai), but the security programme is thin and mostly undocumented. Nine of the sixteen risks assessed are rated High, none are Critical. The two practical tests run in this exercise, a 10-account access review and a 10-source log retention audit, both found real gaps.

16	**risks assessed**	9 High | 6 Medium | 1 Low
6 of 10	**sampled accounts with exceptions**	2 High and 4 Medium findings
3 of 10	**log sources failed the log-control assessment**	Retention, coverage or protection; 4 not evidenced, 1 applicability pending
22	**remediation actions**	11 P1 | 8 P2 | 3 P3, none started

Top five priorities

- F-01 (High): a leaver's GitHub and AWS accounts were still enabled 25 days after he left, with a login two days after leaving. Disable them, investigate the activity, and decide whether it is a reportable incident. The 27 Oct 2026 target has already passed.
- F-02 (High): a developer holds admin rights on the production payroll database through his daily account, with no MFA and no approval. Remove them and use approved, time-limited admin access.
- L-01 (High): the production database is not audited, so nobody could reconstruct who touched payroll data. Turn on audit logging, store it in Mumbai and keep it 180+ days.
- R-02 (High, score 16): MFA is enforced for administrators only. Extend it to all staff, starting with email, GitHub and AWS.
- R-06 (High): there is no tested incident response process, so the CERT-In six-hour reporting window could be missed. Write a short plan, name a contact and run a tabletop exercise.

Common causes

- A weak joiner-mover-leaver process and no regular access reviews (leaver, role-change and dormant-account findings).
- Heavy dependence on one IT Administrator, who owns 11 of the 18 assets (risk R-01).
- Logging that is configured in places but not verified, protected or retained long enough.
- No documented incident, supplier or configuration-management process.

How to read the numbers. Ratings are illustrative scenario estimates, not measured facts. The access sample was chosen by judgement, so its counts describe the sample only and must not be projected to the whole company. Legal mappings are for learning and are marked 'source verification pending' (section 8).

2. Scope, method and assumptions

What was assessed

The assessment covers PayNest's 18 inventoried assets, a 16-item risk register, 21 selected ISO/IEC 27001:2022 Annex A controls (mapped to NIST CSF 2.0 codes), a simulated access review, a simulated log retention audit against the CERT-In 180-day direction, a legal obligations register and a consolidated remediation plan.

Item	Scenario assumption
Company	PayNest, Mumbai. Payroll and employee-management SaaS for SMEs. Founded 2022 (assumed).
Size	35 employees; about 250 customers; about 12,000 customer employee records.
Data	Names, contact details, salary/payroll records and bank account details. PayNest acts as a processor for customer data and a fiduciary for its own staff data (scenario position, to be verified).
Hosting	AWS Mumbai (ap-south-1); mixed office and remote work.
Security staffing	No dedicated security team and no external MSSP. The IT Administrator coordinates security.
Tools	Microsoft Entra ID, AWS IAM, Microsoft 365, GitHub, Defender Antivirus, AWS-native logging and alerting. No integrated SIEM. MFA for administrators only. Daily backups, no documented restore test.

Method

- Risk score = Likelihood (1-5) x Impact (1-5). Bands: 1-4 Low, 5-9 Medium, 10-16 High, 17-25 Critical. Scores are inherent (before treatment); residual risk is left 'Not assessed' until fixes are implemented and tested.
- Business criticality (High / Medium / Low) is about importance of the asset, not a risk score.
- Control status: Implemented, Partially implemented, Not implemented, or Not evidenced (no information either way).
- Access review: 8 rules (AC-01 to AC-08) tested by inspection and reperformance on 10 accounts. Working-day tests exclude weekends but not public holidays.
- Log audit: an assumed setting is never scored as a Pass or a Fail. It stays 'Not evidenced' until the real setting is checked. A Fail needs verified evidence.
- Risk owners are business roles. The IT Administrator owns no risks by design, because they carry out many controls and should not accept the risk that arises from their own concentration of duties.

3. Asset inventory

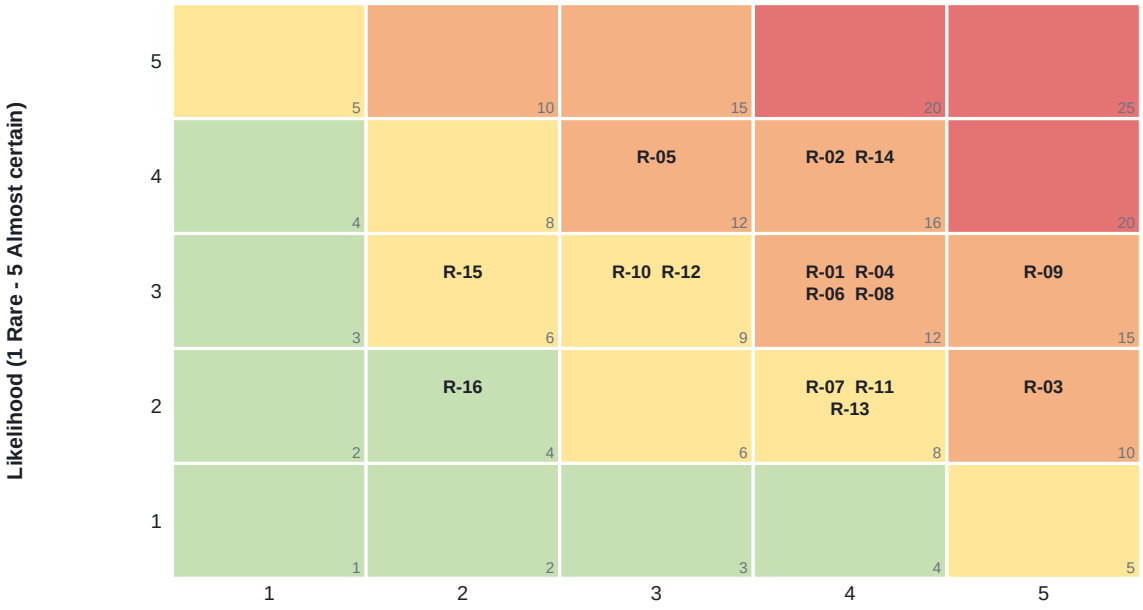
High 9	Medium 7	Low 2

Business criticality of the 18 assets. The IT Administrator is the single accountable owner of 11 of them.

ID	Asset	Type	Owner	Personal data	Class.	Criticality
A-01	Customer payroll and employee records	Data	Product Owner	Yes	Confidential	High
A-02	Payroll application / production web service	Application / SaaS	CTO	Yes	Confidential	High
A-03	Production database	Data store / infrastructure	Engineering Lead	Yes	Confidential	High
A-04	AWS cloud account and hosting environment	Cloud infrastructure	IT Administrator	No	Internal	High
A-05	Identity and access management (SSO / admin identities)	Identity / access	IT Administrator	Yes	Confidential	High
A-06	Employee laptops and workstations	Endpoint devices	IT Administrator	Yes	Internal	Medium
A-07	Source-code repository and CI/CD pipelines	Software / intellectual property	Engineering Lead	No	Confidential	High
A-08	Corporate email and collaboration service	Third-party service / communications	IT Administrator	Yes	Confidential	Medium
A-09	Backups and recovery copies	Data / recovery	IT Administrator	Yes	Confidential	High
A-10	Security and application logs	Logging / monitoring data	IT Administrator	Yes	Confidential	Medium
A-11	Network security controls (firewall, security groups, VPN)	Network / cloud security	IT Administrator	No	Internal	Medium
A-12	Customer support / ticketing platform	Third-party SaaS / business service	Support Lead	Yes	Confidential	Medium
A-13	Payment / bank integration credentials and interface	Integration / secrets	IT Administrator	Yes	Confidential	High
A-14	PayNest employee HR and payroll records	Data	HR Manager	Yes	Confidential	Medium
A-15	Removable storage devices (USB)	Portable media	IT Administrator	No	Internal	Low
A-16	Software licences and subscriptions	Software / vendor licences	Finance Lead	No	Internal	Low
A-17	Third-party vendor and service accounts	Supplier accounts / SaaS services	IT Administrator	Yes	Confidential	High
A-18	Monitoring and alerting capability	Security monitoring service	IT Administrator	No	Internal	Medium

4. Risk assessment

Sixteen risks were rated using the L x I method. The heat map shows where each risk sits. Several share a cell because the scenario evidence is similar (for example, four risks sit at likelihood 3, impact 4).



Inherent rating	Risks
Critical	0
High	9
Medium	6
Low	1
Total	**16**

Risk register

ID	Risk	L	I	Score	Rating	Owner	Target
R-01	Security and IT operations depend heavily on one IT Administrator, creating key-person dependency and potential segregation-of-duties weakness.	3	4	12	High	CEO	31-Jan-2027
R-02	Workforce accounts without MFA could be taken over through phishing or stolen passwords, giving an attacker access to email, source code and cloud services.	4	4	16	High	CTO	31-Dec-2026
R-03	Backups that have never been restore-tested may fail when needed after ransomware, accidental deletion or an outage.	2	5	10	High	Engineering Lead	31-Jan-2027
R-04	With no integrated SIEM or continuous monitoring, an attack could go unnoticed for a long time.	3	4	12	High	CTO	31-Mar-2027
R-05	Logs may not be kept for the rolling 180 days within India that the CERT-In Directions expect, or may not be protected from tampering.	4	3	12	High	Engineering Lead	28-Feb-2027
R-06	No tested incident response and reporting process, so a reportable incident might miss the CERT-In six-hour deadline or breach-notification duties under the data protection law.	3	4	12	High	CEO	28-Feb-2027
R-07	A supplier or SaaS account (cloud, email, code hosting, ticketing, HR system) could be compromised, or supplier terms could leave security duties unclear.	2	4	8	Medium	Finance Lead	31-Mar-2027
R-08	A cloud misconfiguration (for example an overly open security group or broad IAM permission) could expose production systems or data.	3	4	12	High	CTO	31-Jan-2027
R-09	A vulnerability in the payroll application (for example broken access control or injection) could expose or alter customer payroll data.	3	5	15	High	Engineering Lead	28-Feb-2027
R-10	Accounts of leavers or staff who changed roles may stay active or keep excess access across email, cloud, code and SaaS tools.	3	3	9	Medium	HR Manager	31-Jan-2027
R-11	PayNest may not be ready for the data protection law's duties as a processor (contracts, breach support, retention and erasure) when they begin to apply.	2	4	8	Medium	Product Owner	30-Apr-2027
R-12	A lost, stolen or malware-infected laptop could expose credentials or work files.	3	3	9	Medium	CTO	31-Mar-2027
R-13	Credentials for the bank or payment integration could leak (for example through code, CI/CD or excess access to the secrets store).	2	4	8	Medium	Engineering Lead	28-Feb-2027
R-14	Phishing or business email compromise could lead to stolen credentials or fraudulent changes to payroll or bank details.	4	4	16	High	Finance Lead	31-Jan-2027
R-15	Customer support tickets may hold personal data (names, contact details, screenshots) and be visible to too many people or kept for too long.	3	2	6	Medium	Support Lead	31-Mar-2027
R-16	Removable USB media could be lost or used to move data out or bring malware in.	2	2	4	Low	CTO	30-Jun-2027

Owners and ratings are provisional scenario estimates. Residual rating is 'Not assessed' for every risk. R-05 likelihood was raised from 3 to 4 after the log audit found three verified failures.

5. Control assessment (ISO/IEC 27001:2022 Annex A, selected)

21 selected controls were mapped to risks and NIST CSF 2.0 codes. Status is a scenario assumption unless the Test result column says a test was run. This is a starter sample, not a Statement of Applicability or a certification audit.

Partial 10	Not impl. 4	Not evid. 7

Control	Name	Risks	CSF	Status	Test result
5.2	Information security roles and responsibilities	R-01	GV.RR-02; GV.RR-03	Partially implemented	Not tested — scenario assumptions
5.3	Segregation of duties	R-01	GV.RR-03; PR.AA-05	Not implemented	Gap to validate — concentration identified
5.15	Access control	R-01; R-10; R-13; R-15	PR.AA-05	Partially implemented	Tested on sample - see findings
5.16	Identity management	R-10	PR.AA-01; PR.AA-03	Partially implemented	Tested on sample - see findings
5.18	Access rights	R-01; R-02; R-10	PR.AA-05	Partially implemented	Tested on sample - see findings
8.2	Privileged access rights	R-01; R-13	PR.AA-05; DE.CM-03	Partially implemented	Tested on sample - see findings
8.5	Secure authentication	R-02; R-14	PR.AA-03	Partially implemented	Tested on sample - see findings
5.19	Information security in supplier relationships	R-07	GV.SC-07	Not evidenced	Not tested — scenario assumptions
5.20	Addressing information security within supplier agreements	R-07; R-11	GV.SC-05; GV.SC-07	Not evidenced	Not tested — scenario assumptions
5.23	Information security for use of cloud services	R-07; R-08	GV.SC-07; PR.PS-02	Partially implemented	Not tested — scenario assumptions
5.24	Information security incident management planning and preparation	R-06	RS.MA-01; RS.CO-02	Not implemented	Not tested — scenario assumptions
5.26	Response to information security incidents	R-06	RS.MA-02; RS.MI-01	Not implemented	Not tested — scenario assumptions
5.28	Collection of evidence	R-05; R-06	RS.AN-06	Not evidenced	Not tested — scenario assumptions
8.13	Information backup	R-03	PR.DS-11; RC.RP-03	Partially implemented	Gap to validate — restore tests not evidenced
8.15	Logging	R-04; R-05	DE.CM-01; DE.CM-03	Partially implemented	Tested on sample - see findings
8.16	Monitoring activities	R-04	DE.CM-01; DE.AE-02	Partially implemented	Gap to validate — integrated SIEM not assumed
8.8	Management of technical vulnerabilities	R-09; R-12	ID.RA-01; PR.PS-02	Not evidenced	Not tested — scenario assumptions
8.9	Configuration management	R-08; R-09; R-12; R-16	PR.PS-01; PR.PS-02	Not evidenced	Not tested — scenario assumptions
5.31	Legal, statutory, regulatory and contractual requirements	R-05; R-11	GV.OC-03; GV.PO-01	Not implemented	Not tested — scenario assumptions
5.34	Privacy and protection of PII	R-11; R-15	GV.OC-03; PR.DS-01	Not evidenced	Not tested — scenario assumptions
6.3	Information security awareness, education and training	R-14	PR.AT-01	Not evidenced	Not tested — scenario assumptions

6. Access review

Ten accounts were chosen by judgement so that each risk type was represented (privileged, leaver, role change, dormant, service, shared, and some expected to be fine). Each was tested against eight rules. Result: 4 compliant, 6 with exceptions, 6 findings (2 High, 4 Medium) and one test that could not be evidenced (least privilege for the service account). Review date: 25 Oct 2026.

ID	Username	Role	Privilege	MFA	Fails	Result
ACC-01	priya.nair-admin	CTO	Privileged (admin)	Y	0	Compliant
ACC-02	rohan.mehta-adm	IT Administrator	Privileged (admin)	Y	0	Compliant
ACC-03	sneha.kulkarni	HR Manager	Standard	N	0	Compliant
ACC-04	vikram.joshi	Support Lead	Standard	N	0	Compliant
ACC-05	arjun.desai	Software Developer	Standard	N	2	Exception
ACC-06	karan.shah	Software Developer	Privileged (database admin)	N	3	Exception
ACC-07	support-shared	Support team	Standard	N	2	Exception
ACC-08	svc-payroll-batch	Payroll batch job	Privileged (write to payroll storage)	N	2	Exception
ACC-09	divya.menon	Finance Executive (was Support Agent)	Privileged (tool admin)	N	4	Exception
ACC-10	sanjay.kapoor	Contract Engineer	Standard	N	1	Exception

Access findings

ID	Account	What was found	Severity	Owner	Due
F-01	arjun.desai	HR shows a leave date of 30-Sep-2026. The GitHub and AWS accounts were still enabled 25 days later, and the last login was on 02-Oct-2026, after he had left.	High	IT Administrator	27-Oct-2026
F-02	karan.shah	A developer holds admin rights on the production database through his daily account, with MFA off and no approval reference.	High	CTO	06-Nov-2026
F-03	support-shared	One ticketing login is shared by three support agents, with no named owner.	Medium	Support Lead	20-Nov-2026
F-04	svc-payroll-batch	A non-interactive service account uses long-lived access keys with write access to payroll storage. It has no named owner or documented purpose, and how the keys are stored and rotated, and whether writes are logged or alerted, is not evidenced.	Medium	CTO	20-Nov-2026
F-05	divya.menon	She moved from Support to Finance on 15-Aug-2026 and still has ticketing admin rights 71 days later, with MFA off. The approval on file relates to her old role.	Medium	Support Lead	13-Nov-2026
F-06	sanjay.kapoor	A contractor guest account with read access to source code has not logged in for 127 days, although the contract is active, and no dormancy review or business justification is recorded.	Medium	Engineering Lead	13-Nov-2026

Observation O-01: standard staff accounts have no MFA. This is outside rule AC-03 (admins and payroll-data accounts) so it is not a finding, but it remains a gap tracked as risk R-02.

7. Log retention audit (CERT-In 180-day requirement)

Ten log sources were tested against the requirement to keep ICT logs for a rolling 180 days within India. Only AWS CloudTrail and VPC flow logs were verified at 180 days or more in Mumbai with a retrieval test. The most serious gap is the unaudited production database. Entra ID and ticketing retention values are assumed, so they stay 'Not evidenced' instead of being scored as failures.

Pass 2	Fail 3	Not evidenced 4	Pending 1

ID	Log source	Days	Evidence	In India?	Result
LS-01	AWS CloudTrail (management events)	365	Verified	Y	Pass
LS-02	Application logs	30	Verified	Y	Fail
LS-03	Database audit logs	0	Verified	Unknown	Fail
LS-04	Network flow logs	180	Verified	Y	Pass
LS-05	Entra ID sign-in and audit logs	30	Assumed	Unknown	Not evidenced
LS-06	Microsoft 365 email and audit logs	180	Assumed	Unknown	Not evidenced
LS-07	GitHub organisation audit log	180	Assumed	N	Applicability pending
LS-08	Endpoint security logs	-	None	Unknown	Not evidenced
LS-09	Ticketing tool audit log	90	Assumed	Unknown	Not evidenced
LS-10	Web application access logs	180	Verified	Y	Fail

Log findings

ID	Source	What was found	Severity	Owner	Due
L-01	Database audit logs	Auditing is not enabled on the production database, so there is no record of who accessed or changed payroll data.	High	Engineering Lead	20-Nov-2026
L-02	Application logs	Application logs are kept for 30 days, below the 180-day requirement.	Medium	Engineering Lead	30-Nov-2026
L-03	Entra ID sign-in and audit logs	Retention of about 30 days is ASSUMED from the licence default and the logs are not exported. The actual tenant setting has not been checked (source result: Not evidenced).	Medium	IT Administrator	15-Dec-2026
L-04	GitHub organisation audit log	Observed fact: the audit log is held by GitHub outside India, and 180-day retention is assumed, not verified. Whether the CERT-In in-India log requirement applies to a SaaS provider's logs is not settled. Legal compliance conclusion: Applicability pending confirmation.	Medium	CTO	15-Dec-2026
L-05	Ticketing tool audit log	A vendor default of 90 days is ASSUMED. The actual plan setting has not been checked (source result: Not evidenced).	Low	Support Lead	31-Jan-2027
L-06	Web application access logs	Logs are kept for 180 days in Mumbai, but the developer group can read and delete them.	Medium	CTO	15-Dec-2026
L-07	Microsoft 365 audit logs; endpoint security logs	Retention, location and protection are unverified for email audit logs, and endpoint logs are not collected centrally.	Low	IT Administrator	31-Jan-2027
L-08	Clock synchronisation	Clock synchronisation is tested separately (Log Retention Audit, column U), not in the source-level result. It is recorded as Yes for 5 sources (AWS CloudTrail, application logs / CloudWatch, network flow logs, Entra ID and web application access logs) and is not evidenced for the other 5.	Low	IT Administrator	31-Jan-2027

Clock synchronisation is a separate supporting test (5 sources pass, 5 not evidenced) and is not part of the source-level result. GitHub (LS-07) is held outside India; whether the in-India log requirement applies to a SaaS provider's logs is unsettled, so the conclusion is 'Applicability pending'.

8. Legal and regulatory mapping

Read this first. This register is a learning exercise, not legal advice. Every row's 'Date checked' is still *Not verified* in the workbook, so none of these points should be treated as a legal conclusion until the official source has been opened and the date recorded.

Key timeline points (as summarised in the workbook)

- The workbook records IT Act s.43A and the 2011 SPDI Rules as the existing data-protection baseline, with s.43A expected to be omitted when DPDP Act s.44(2) commences. Their current legal status and applicability should be confirmed against the official legislation and commencement notifications.
- The workbook records DPDP Rules 2025 as notified on 13 Nov 2025 with phased commencement, and Rules 3, 5 to 16, 22 and 23 (including Rule 6 safeguards and Rule 7 breach intimation) scheduled for 13 May 2027. The dates and any later amendments are pending official-source verification.
- The workbook also notes a DPDP Removal of Difficulties Order dated 5 Oct 2026 correcting wording in ss.9 and 10, with no change to the commencement timeline. This is pending official-source verification.
- The workbook summarises the CERT-In Directions (28 Apr 2022) as requiring incident reports within six hours, ICT logs kept for a rolling 180 days within India, and time-synchronisation and point-of-contact arrangements. The exact wording is pending verification.
- RBI IT governance and outsourcing directions are not assumed to apply directly (PayNest is not an RBI-regulated entity), but customer contracts may flow requirements down. Applicability is unconfirmed.

Source	Topic	Applies to PayNest? (scenario view)	Date checked
Information Technology Act, 2000 — s.43A and the IT (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011	Reasonable security practices for sensitive personal data (workbook position; status unverified)	Likely relevant today: PayNest is a company holding bank account details in its systems. The workbook records Section 43A as expected to be omitted when section 44(2) of the DPDP Act commences, currently scheduled for 13-May-2027. This timeline and the present legal status of the IT Act and SPDI Rules remain subject to verification against official legislation and commencement notifications. How it applies to a processor handling customers' data depends on the facts and contracts.	Not verified
DPDP Act, 2023 — s.8(5) and related breach duties; subject to commencement	Reasonable security safeguards / personal data breach	Future statutory obligation for the described processing, subject to actual scope and the notified commencement timeline; assess readiness now.	Not verified
DPDP Act, 2023 — ss.4–6; related DPDP Rules	Lawful processing, notice and consent where applicable	Assess as a future obligation for provisions not yet commenced; actual applicability depends on processing purpose, role, exclusions and commencement.	Not verified
DPDP Rules, 2025 — Rule 1 commencement	Phased commencement	Relevant for tracking when obligations become operative. Under the commencement notification dated 13-Nov-2025, the 18-month tranche is scheduled for 13-May-2027, subject to subsequent official amendments or notifications.	Not verified
CERT-In Directions under IT Act s.70B(6), 28-Apr-2022 — reporting direction	Report specified cyber incidents within six hours	Likely relevant to PayNest as a body corporate within the Direction's scope; verify precise incident type and applicability against the official Direction/FAQ.	Not verified
CERT-In Directions, 2022 — log retention direction	ICT logs: rolling 180 days within Indian jurisdiction	Likely relevant to PayNest as a body corporate; validate the covered systems, retention implementation and any applicable clarification.	Not verified
CERT-In Directions, 2022 — point of contact / time synchronisation	Contact and time integrity	Likely relevant; verify the precise Direction clauses and PayNest's systems and operations.	Not verified
Information Technology Act, 2000 — ss.43 and 66	Unauthorised access / specified computer-related acts	Relevant as a general legal framework for computer resources; does not itself mean PayNest has breached the law.	Not verified
Information Technology Act, 2000 — s.70B and CERT-In Directions	CERT-In authority and directions	Relevant to evaluating applicable CERT-In directions; the concrete obligations are captured in separate rows above.	Not verified
Information Technology Act, 2000 — ss.65, 66C–66F, 67, 67A, 67B, 69, 69A, 70, 70A	Selected computer offences, government powers and protected systems	General legal context only; applicability depends on the incident and the activity.	Not verified
RBI IT Governance Directions, 2023	Financial-sector IT governance and assurance	Not assumed to apply directly: PayNest is a fictional payroll SaaS provider, not assumed to be an RBI-regulated bank/NBFC/payment system operator. Contractual flow-down or relevant outsourcing relationships may still matter.	Not verified

Source	Topic	Applies to PayNest? (scenario view)	Date checked
RBI IT Outsourcing Directions, 2023	Third-party and outsourced IT services	Not assumed directly applicable to PayNest as a regulated entity; relevant customer contracts or outsourcing arrangements may impose requirements that need assessment.	Not verified

9. Remediation plan

The plan combines the six access findings, eight log findings and eight treatments for High-rated risks. R-05 (High) has no separate action row because it is treated through findings L-01 to L-08. Priority: P1 = High, P2 = Medium, P3 = Low. Target dates are scenario proposals. Every action is 'Not started' and none has been retested.

Ref	Pri.	Risk	Action	Owner	Target
F-01 **OVERDUE**	P1	R-10; R-06	Disable both accounts now. Review activity since 30-Sep-2026, rotate any keys or secrets he could access, and decide whether it is a reportable incident. Make HR send a leaver notice that triggers account removal within 1 working day.	IT Administrator	27-Oct-2026
F-02	P1	R-01; R-02; R-08	Remove the production admin rights. Use approved, time-limited access through a separate admin account with MFA. Review database access logs for the period. Add admin access requests to the approval process.	CTO	06-Nov-2026
L-01	P1	R-05; R-09; R-06	Enable database audit logging for admin activity and payroll-table access, send it to protected storage in Mumbai, keep it 180+ days and test a retrieval.	Engineering Lead	20-Nov-2026
RT-R-02	P1	R-02	Enforce MFA for all staff accounts, starting with email, GitHub and AWS; use phishing-resistant methods for administrators; review MFA coverage monthly.	CTO	31-Dec-2026
RT-R-01	P1	R-01	Name a deputy and define escalation coverage; require independent approval and periodic review of privileged access and sensitive changes; separate request, approval, and execution where feasible; document cross-training and absence coverage; reassess whether external monitoring is justified.	CEO	31-Jan-2027
RT-R-03	P1	R-03	Run and document a restore test every quarter; define recovery time and recovery point targets; keep a copy protected against deletion by a single account.	Engineering Lead	31-Jan-2027
RT-R-08	P1	R-08	Define a secure baseline; run monthly reviews of security groups and IAM permissions; require a second person to approve production changes; turn on configuration change alerts.	CTO	31-Jan-2027
RT-R-14	P1	R-14	Run awareness training twice a year; require a second check and a call-back for bank-detail changes; add MFA and email filtering settings; run a simulated phishing test.	Finance Lead	31-Jan-2027
RT-R-06	P1	R-06	Write a short incident response plan with a severity matrix and a named point of contact; record the time an incident is noticed; run a tabletop exercise twice a year; prepare report templates.	CEO	28-Feb-2027
RT-R-09	P1	R-09	Add dependency and code scanning to the pipeline; set patch timelines by severity; commission an independent security test before major releases; log and review access to payroll data.	Engineering Lead	28-Feb-2027
RT-R-04	P1	R-04	Define priority alerts and who reviews them; centralise key logs; assess a low-cost SIEM or an external monitoring service; test alerts with simulated events.	CTO	31-Mar-2027
F-05	P2	R-10; R-15; R-02	Remove admin rights and keep only what her Finance role needs. Enable MFA on all admin accounts, including SaaS tools. Add role-change events to the HR trigger for access updates.	Support Lead	13-Nov-2026
F-06	P2	R-10	Ask the Engineering Lead whether it is still needed. If not, disable it. Set automatic expiry dates for contractor accounts.	Engineering Lead	13-Nov-2026
F-03	P2	R-15; R-10	Disable the shared login and replace it with named accounts using role-based access. Record any exception with an owner and a reason.	Support Lead	20-Nov-2026
F-04	P2	R-10	Assign an owner and document the purpose now. Establish what permissions the job really needs and cut the rest. Replace access keys with an IAM role where possible, rotate any remaining keys, and confirm that writes are logged and alerted. Re-rate the finding once these facts are known.	CTO	20-Nov-2026
L-02	P2	R-05; R-09	Raise retention to at least 180 days with an archive in Mumbai using lifecycle rules, then run a retrieval test.	Engineering Lead	30-Nov-2026
L-03	P2	R-05; R-02	Export sign-in and audit logs to protected storage in Mumbai, keep them 180+ days, and confirm the tenant's data location.	IT Administrator	15-Dec-2026

Ref	Pri.	Risk	Action	Owner	Target
L-04	P2	R-05; R-13	Confirm applicability with legal advice (by 30-Nov-2026). Streaming the audit log to protected storage in Mumbai is an interim risk-reduction measure, not proof that the legal requirement is satisfied.	CTO	15-Dec-2026
L-06	P2	R-05; R-08	Make the bucket read-only for investigators, deny delete, and enable object lock or versioning.	CTO	15-Dec-2026
L-05	P3	R-05; R-15	Check what the plan allows. Export the audit log monthly or move to a plan with longer retention.	Support Lead	31-Jan-2027
L-07	P3	R-05; R-12; R-14	Verify and record the retention setting and tenant location for Microsoft 365, and forward endpoint alerts to central storage with 180-day retention.	IT Administrator	31-Jan-2027
L-08	P3	R-05; R-06	Confirm the time source for each system, configure the approved servers where possible and record the evidence.	IT Administrator	31-Jan-2027

F-01 is flagged overdue: its 27 Oct 2026 target had passed at the 2 Nov 2026 plan date with the action not started. No action should be marked complete without remediation evidence and a retest.

10. Limitations and next steps

- Everything here is fictional. Company facts, account data, log settings and dates are invented for practice, and ratings are scenario estimates.
- The access sample (10 of roughly 50 accounts) is judgemental, so its results cannot be extrapolated.
- Control statuses are assumptions unless a test is referenced. Nothing here proves compliance with ISO 27001, NIST CSF, the IT Act, the DPDP Act or CERT-In Directions.
- Legal points need verification against official sources, with the 'Date checked' recorded only when someone has actually opened the source.
- If this were a real engagement, the next steps would be: replace assumptions with evidence, challenge the ratings with the risk owners, fix and retest the P1 actions, then re-issue this report.

Appendix: NIST CSF 2.0 functions used

Function	Plain meaning	Codes referenced
Govern (GV)	Set direction, assign responsibility, understand obligations and manage cyber risk at leadership level.	GV.OC-01; GV.OC-03; GV.RM-02; GV.RR-02; GV.PO-02; GV.SC-07
Identify (ID)	Know which assets and risks matter, and keep inventories and risk information current.	ID.AM-01; ID.AM-02; ID.AM-07; ID.AM-08; ID.RA-01; ID.IM-01
Protect (PR)	Put safeguards in place to reduce the chance or impact of a cyber incident.	PR.AA-01; PR.AA-03; PR.AA-05; PR.AT-01; PR.DS-01; PR.DS-11; PR.PS-01; PR.PS-02; PR.IR-01
Detect (DE)	Notice suspicious activity and assess whether it may be a security incident.	DE.CM-01; DE.CM-03; DE.CM-09; DE.AE-02; DE.AE-03; DE.AE-06; DE.AE-07
Respond (RS)	Coordinate investigation, communication and containment when an incident occurs.	RS.MA-01; RS.MA-02; RS.AN-03; RS.AN-06; RS.CO-02; RS.MI-01; RS.MI-02
Recover (RC)	Restore affected services and data safely, then communicate recovery status.	RC.RP-01; RC.RP-02; RC.RP-03; RC.CO-03